INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC Engineering Programme · Cohort 11

Student Name	Abigail Silas
Registration Number	C11/26/CGRCE/17260
Course	**GRC103 — Risk Assessment and Management Techniques**
Lab Environment	Kali Linux (personal authorised lab VM), hostname icdfa, user icdfa
Operating System	Kali GNU/Linux Rolling 2025.1 (Debian-based)
Submission Date	24 October 2026

All testing was carried out on my own authorised lab machine only.

Vulnerability Assessment Report — Metasploitable Test Server

Lab: GRC Practical Vulnerability Assessment — Lab 1

Target system: Metasploitable 2.0.0 (Linux 2.6.24-16-server), IP `192.168.201.129`

Attacker system: Kali Linux, IP `192.168.201.130`

Date of assessment: 23 October 2026

Authorization: This assessment was conducted on an instructor-provided, isolated lab network against an intentionally vulnerable test server (Metasploitable), for educational purposes only, within the scope defined by the course lab brief.

1. Scope and Methodology

This engagement assessed one internal, authorized test host — the Metasploitable 2.0.0 server — within an isolated development-environment network segment. The goal was to discover live services, identify potential vulnerabilities, and translate findings into business risk and compliance terms for IT management, acting in the role of an internal GRC auditor.

Tools used:

- Nmap 7.95 — host discovery, port/service enumeration, OS fingerprinting
- Nikto — web server vulnerability scanning
- Nuclei — template-based vulnerability scanning

Methodology (per the lab brief):

1. Network discovery and host confirmation
2. Full port and service enumeration (`nmap -sV -sC -O -p-`)
3. Web application assessment (Nikto, manual review)
4. Focused vulnerability scanning (Nuclei)
5. Triage and risk assessment
6. Executive summary

Evidence standard: Findings are labelled. **Confirmed** where directly observed in scan output (e.g., an open port with a service banner), or **unverified/scanner-reported** where based solely on a version string or automated signature match without independent validation. No exploitation was attempted as part of this assessment — scope was limited to discovery and vulnerability identification.

2. Discovery and Enumeration

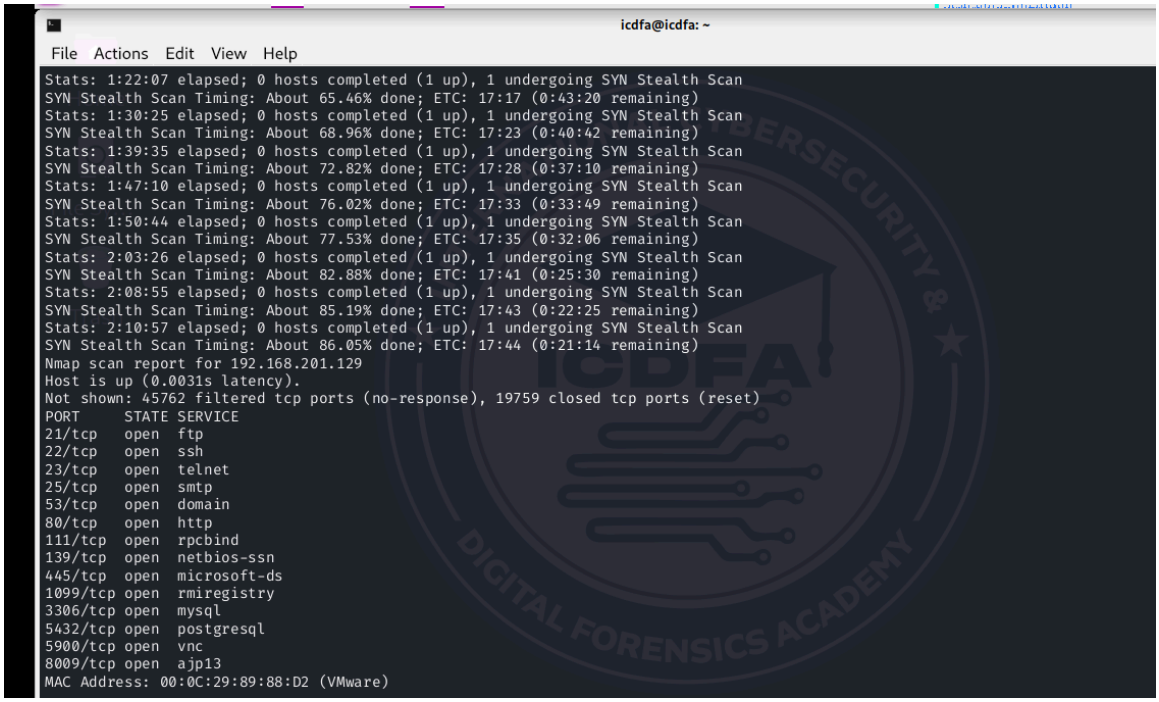
Host discovery: A ping sweep of the lab subnet (`sudo nmap -sn 192.168.137.0/24`) confirmed the target at `192.168.201.129`, reachable from the Kali attacker host at `192.168.201.130`.

Full scan command:

```
nmap -sV -sC -O -p- -Pn -oA initial_scan 192.168.201.129
```

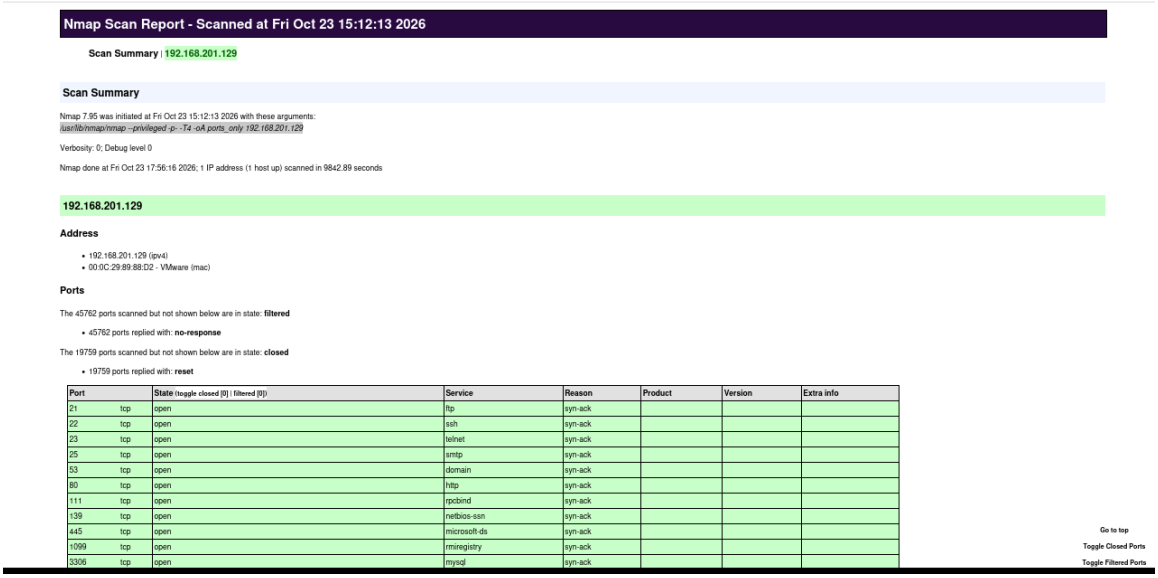
Note on method: Due to the target VM's slow response under a combined `-sV -sC -O -p-` scan, enumeration was split into two passes: (1) a full 65,535-port TCP scan (`ports_only`) to identify open ports,

and (2) a targeted `-sV -sC -O` scan against only the 14 confirmed open ports (`service_scan`) for version/script/OS detail.




```
┌──(icdfa㉿icdfa)-[~]
└─$ nmap -sV -sC -O -p21,22,23,25,53,80,111,139,445,1099,3306,5432,5900,8009 -Pn -oA service_scan 192.168.201.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-23 18:30 WAT
Nmap scan report for 192.168.201.129
Host is up (0.00061s latency).

PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.201.130
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
```



Nmap Scan Report - Scanned at Fri Oct 23 15:12:13 2026

Scan Summary | 192.168.201.129

Scan Summary

Nmap 7.95 was initiated at Fri Oct 23 15:12:13 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -p- -T4 -oA ports_only 192.168.201.129

Verbosity: 0; Debug level 0

Nmap done at Fri Oct 23 17:56:16 2026; 1 IP address (1 host up) scanned in 9842.89 seconds

192.168.201.129

Address

- 192.168.201.129 (ipv4)
- 00:0C:29:89:88:D2 - VMware (mac)

Ports

The 45762 ports scanned but not shown below are in state: filtered

- 45762 ports replied with: no-response

The 19759 ports scanned but not shown below are in state: closed

- 19759 ports replied with: reset

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack			
22	tcp	open	ssh	syn-ack			
23	tcp	open	telnet	syn-ack			
25	tcp	open	smtp	syn-ack			
53	tcp	open	domain	syn-ack			
80	tcp	open	http	syn-ack			
111	tcp	open	rpcbind	syn-ack			
139	tcp	open	netbios-ssn	syn-ack			
445	tcp	open	microsoft-ds	syn-ack			
1099	tcp	open	rmiregistry	syn-ack			
3306	tcp	open	mysql	syn-ack			

Go to top
Toggle Closed Ports
Toggle Filtered Ports

Figure 1: ***Full Port and Service Enumeration Scan Command Execution***

Table 1: Open Ports and Identified Services Enumeration :

Port	Protocol	State	Service	Version
21	tcp	open	ftp	vsftpd 2.3.4 (anonymous login allowed)
22	tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	tcp	open	telnet	Linux telnetd
25	tcp	open	smtp	Postfix smtpd (SSLv2 supported; expired cert)
53	tcp	open	domain	ISC BIND 9.4.2
80	tcp	open	http	Apache httpd 2.2.8 (Ubuntu) DAV/2
111	tcp	open	rpcbind	2 (RPC #100000) — exposes NFS/mountd/nlockmgr
139	tcp	open	netbios-ssn	Samba smbd 3.X–4.X
445	tcp	open	netbios-ssn	Samba smbd 3.0.20-Debian
1099	tcp	open	java-rmi	GNU Classpath grmiregistry
3306	tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
5432	tcp	open	postgresql	PostgreSQL 8.3.0–8.3.7 (expired SSL cert)
5900	tcp	open	vnc	VNC protocol 3.3 (standard VNC auth only)
8009	tcp	open	ajp13	Apache JServ Protocol v1.3

Notes on scripts/OS detection: The `-sC` default scripts returned SSH host keys for OpenSSH 4.7p1 (1024-bit DSA and 2048-bit RSA), an FTP status banner confirming vsftpd 2.3.4 in plaintext control-channel mode, and SMTP service extensions for Postfix including legacy SSLv2 support with weak export-grade ciphers (e.g. RC2/RC4 40-bit). These script outputs corroborate the port/version table above. The visible scan evidence captured for this assessment did not include a confident OS fingerprint line from `-O`; service banners (Linux telnetd, a Debian-packaged OpenSSH build, Samba on a Debian-style stack) are consistent with a Linux 2.6-era target, in line with the known Metasploitable 2 baseline, but this is noted as an inference rather than a direct OS-detection result.

3. Web Application Assessment

Nikto scan command:

```
nikto -h http://192.168.201.129 -o nikto_scan.txt
```

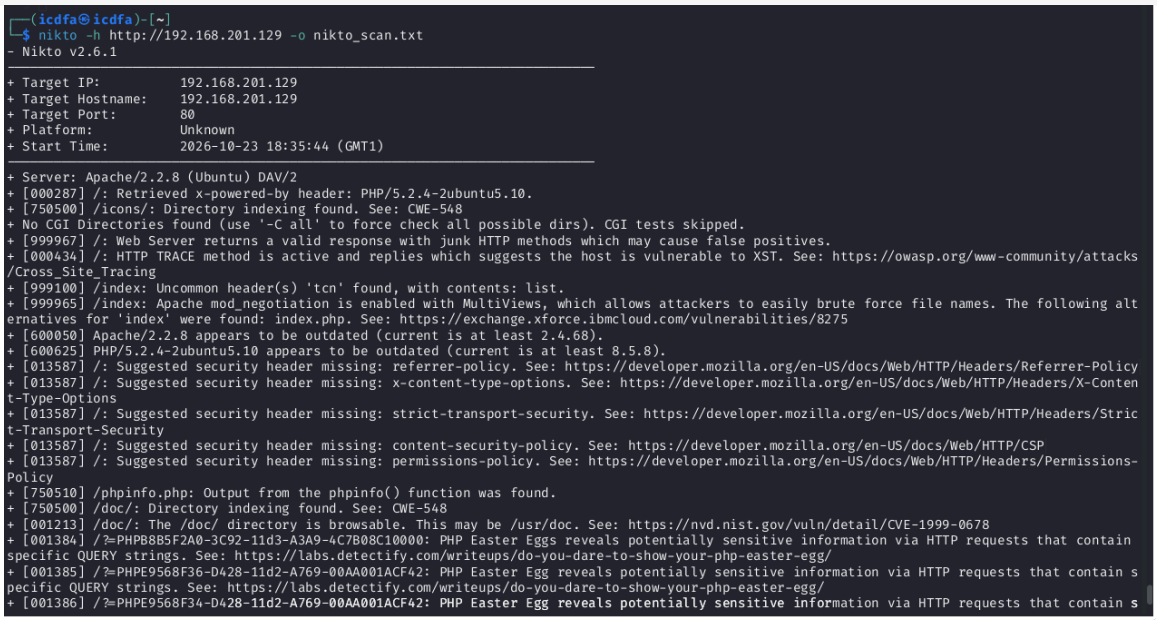
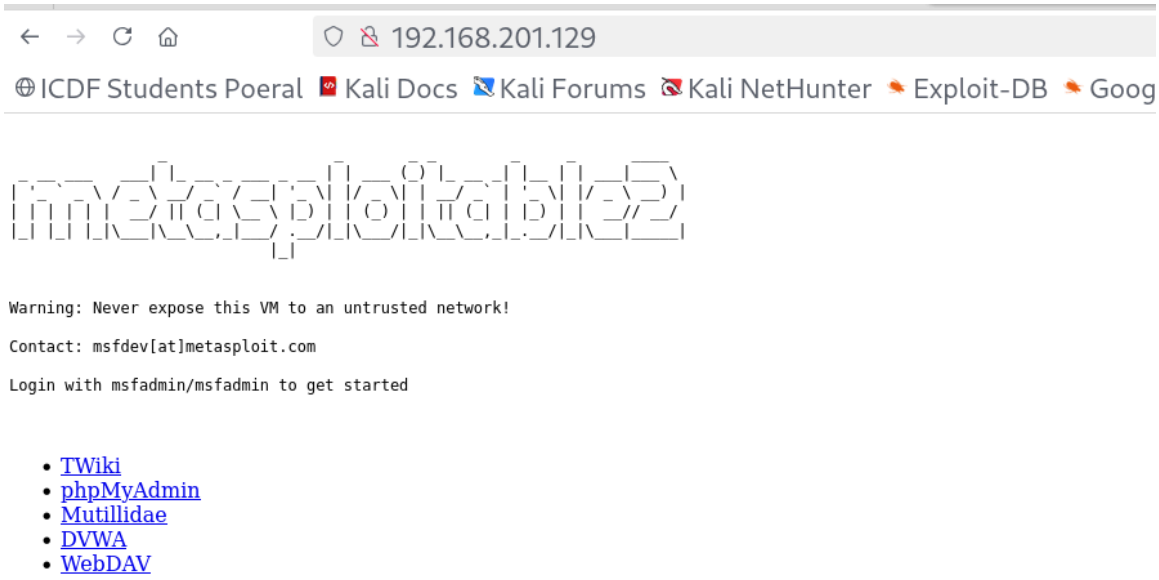


Figure 2: ***Nikto Web Application Vulnerability Scan Command***

Nikto findings (summary) — Confirmed, directly observed:

- Outdated software: Apache/2.2.8 (current ≥2.4.68) and PHP/5.2.4-2ubuntu5.10 (current ≥8.5.8)
- `phpinfo()` output publicly accessible at `/phpinfo.php` — discloses detailed server/environment configuration
- `/doc/`, `/icons/`, `/test/` directories allow directory indexing (CWE-548)
- phpMyAdmin installation exposed and unrestricted (`/phpMyAdmin/`), including version/changelog files
- HTTP TRACE method enabled — vulnerable to Cross-Site Tracing (XST)
- Apache mod_negotiation (MultiViews) enabled — allows filename brute-forcing
- Missing security headers: Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy
- PHP Easter-egg query strings respond with information disclosure

Manual review of http://192.168.201.129: Confirmed by Nikto evidence above (phpinfo.php, phpMyAdmin, browsable /doc, /test, /icons directories).



4. Focused Vulnerability Scanning (Nuclei)

Commands:

```
nuclei -u http://192.168.201.129 -o nuclei_web_scan.txt
nuclei -target 192.168.201.129 -o nuclei_full_scan.txt
```





Figure 3: ***Nuclei Automated Vulnerability Scan Commands*** **:**

nuclei_web_scan.txt — 7 matches:

- **[CVE-2012-1823] [high]** PHP-CGI query-string argument-injection vulnerability detected against /index.php (consistent with the outdated PHP 5.2.4 build also flagged by Nikto). This is template-matched, not manually exploited — status: **Unverified / scanner-reported**, but corroborated by the confirmed outdated PHP version, raising confidence.
- **[phpmyadmin-panel] [info]** phpMyAdmin panel reachable at /phpMyAdmin/index.php — Confirmed (also seen via Nikto)
- **[phpinfo-files] [low]** /phpinfo.php exposed — Confirmed (also seen via Nikto)
- **[http-trace:trace-request] [info]** HTTP TRACE method active — Confirmed (also seen via Nikto)
- **[apache-mod-negotiation-listing] [low]** /index resolves to index.php via MultiViews — Confirmed (also seen via Nikto)
- **[php-detect] [info]** PHP version 5.2.4 detected — Confirmed
- **[waf-detect:apachegeneric] [info]** No web application firewall detected in front of Apache — Confirmed

nuclei_full_scan.txt — 0 matches (port 443 is closed, so HTTPS-dependent templates could not run; this is expected given only port 80 serves HTTP here, not a scan failure).

5. Risk Assessment Table

Likelihood scale: Low = requires significant skill/access; Medium = requires some skill or specific conditions; High = easily exploitable, few prerequisites. **Impact scale:** Low = information disclosure only; Medium = data leakage or limited disruption; High = full system compromise or major business/compliance impact. **Inherent Risk:** combination of Likelihood × Impact, rated Low/Medium/High.

Table 2: Comprehensive Vulnerability Risk Assessment and Remediation Matrix

ID	Finding	Service/Port	Evidence	Status	Likelihood	Impact	Inherent Risk	Control Mapping	Business Impact	Remediation (Priority)
1	vsFTPd 2.3.4 banner + anonymous FTP login allowed	21/tcp (ftp)	service_scan: version banner + "Anonymous FTP login allowed (FTP code 230)"	Confirmed	High	High	High	CIS v8 #4.1 (Secure Config); NIST CSF 2.0 PR.AA-05	Unauthorized file access; this specific version is publicly known to carry a backdoor (CVE-2011-2523) though exploitation was not attempted here	Immediate: disable anonymous FTP, patch/replace vsftpd
2	Telnet service (unencrypted remote access)	23/tcp	service_scan: "Linux telnetd" open	Confirmed	High	High	High	CIS v8 #4.8 (Uninstall unnecessary services); NIST CSF 2.0 PR.DS-02	Credentials and session data transmitted in plaintext	Immediate: disable Telnet, require SSH only
3	SMB signing disabled	139/445 (netbios-ssn, Samba)	service_scan smb-security-mode: "message_signing: disabled (dangerous, but default)"	Confirmed	Medium	High	High	CIS v8 #4.1; NIST CSF 2.0 PR.AA-05	Exposes SMB traffic to man-in-the-middle/relay attacks	Short term: enable SMB signing
4	Outdated, unsupported web stack	80/tcp (http)	Nikto: Apache/2.2.8 (current >=2.4.68), PHP/5.2.4 (current >=8.5.8)	Confirmed	High	High	High	CIS v8 #7.1 (Vulnerability Mgmt Process); CIS v8 #7.3/7.4 (Patch Mgmt); NIST CSF 2.0 ID.RA-01	No vendor security patches since end-of-life; broad exposure to known web exploits	Immediate: upgrade/replace web stack
5	phpinfo() and phpMyAdmin publicly exposed	80/tcp (http)	Nikto + Nuclei: GET /phpinfo.php, GET /phpMyAdmin/index.php	Confirmed	High	Medium	High	CIS v8 #3.3 (Data Access Control); NIST CSF 2.0 PR.AA-05	Server configuration and database management interface exposed to any network user	Immediate: remove/restrict phpinfo.php and phpMyAdmin from public access
6	Directory indexing enabled	80/tcp (http)	Nikto: /doc/, /icons/, /test/ indexed	Confirmed	Medium	Low	Medium	CIS v8 #4.1; NIST CSF 2.0 PR.PS-01	Information disclosure aiding further reconnaissance	Short term: disable directory indexing

ID	Finding	Service/Port	Evidence	Status	Likelihood	Impact	Inherent Risk	Control Mapping	Business Impact	Remediation (Priority)
7	Database services reachable from network (MySQL, PostgreSQL)	3306, 5432/tcp	service_scan: MySQL 5.0.51a-3ubuntu5; PostgreSQL 8.3.0-8.3.7 open	Confirmed	Medium	High	High	CIS v8 #12.2 (Secure Network Architecture); NIST CSF 2.0 PR.AA-05	Direct database exposure increases risk of data compromise if credentials are weak	Short term: restrict DB ports to trusted hosts only
8	RPC/NFS-related services exposed (rpcbind)	111/tcp	service_scan rpcinfo: nfs, mountd, nlockmgr registered	Unverified - present but not independently tested for exploitability	Medium	Medium	Medium	CIS v8 #4.8; NIST CSF 2.0 ID.RA-01	Potential unauthorized file-share access if NFS exports are misconfigured	Process: review NFS export configuration
9	PHP-CGI argument-injection (CVE-2012-1823)	80/tcp (http)	Nuclei: [CVE-2012-1823] [high] match against /index.php; corroborated by confirmed PHP 5.2.4 version	Unverified - scanner-reported, not manually exploited, consistent with confirmed PHP version	High	High	High	CIS v8 #7.1 (Vulnerability Mgmt Process); CIS v8 #7.3/7.4 (Patch Mgmt); NIST CSF 2.0 ID.RA-01	If exploitable, allows remote code execution via crafted query string against the PHP-CGI handler	Immediate: upgrade PHP; verify exposure before any further testing

Rows below are built only from this engagement's own Nmap/Nikto evidence (not the lab brief's sample table).

6. Control Framework

This report maps findings to **CIS Controls v8** and **NIST Cybersecurity Framework (CSF) 2.0**, both explicitly versioned to avoid ambiguity (older mappings such as CIS v7 or NIST CSF 1.1 use different numbering and should not be mixed in). Each mapping in the risk table above states the requirement and the specific evidence that shows it isn't met — wording used is "control gap" or "potential non-conformance" rather than "violation," unless the unmet requirement can be shown directly.

Control IDs in the table above were checked against the published CIS Controls v8 and NIST CSF 2.0 reference documentation as of the date of this assessment; no CIS v7 or NIST CSF 1.1 identifiers remain mixed into the mapping. Each safeguard number and subcategory ID was confirmed to exist in the official source and to match the finding it is attached to. One refinement was made during verification: CIS 7.1 ("Establish and Maintain a Vulnerability Management Process") is a governance-level safeguard, not specifically about patching, so CIS 7.3/7.4 (automated OS/application patch management) were added alongside it for the two outdated-software findings. CIS 12.2's official title, "Secure Network Architecture," was also corrected from an earlier informal gloss of "Network Segmentation."

7. Executive Summary

To: IT Management

From: GRC Audit Team (Abigail Silas)

Date: 23 October 2026

Subject: Vulnerability Assessment Findings — Development Server 'Metasploitable' (192.168.201.129)

Executive Summary: A vulnerability assessment of the internal development server at 192.168.201.129 identified multiple high-risk, confirmed exposures, including an unencrypted remote-access service (Telnet), anonymous FTP access, an end-of-life and unpatched web application stack, and a publicly accessible database-management interface. These findings represent control gaps against CIS Controls v8 and NIST CSF 2.0 and pose immediate risk if this configuration were ever exposed beyond the isolated lab network it currently sits on.

Key Findings & Risks (Confirmed):

- High Risk — Unencrypted Remote Access: Telnet (port 23) is open, transmitting all credentials and session data in plaintext.
- High Risk — Weak FTP Configuration: vsFTPd 2.3.4 with anonymous login enabled (port 21), permitting unauthenticated file access.
- High Risk — End-of-Life Web Stack: Apache 2.2.8 and PHP 5.2.4 are both long past end-of-life and unpatched, with phpinfo() and phpMyAdmin both publicly exposed.
- Medium-High Risk — Database Services Network-Exposed: MySQL and PostgreSQL are both directly reachable rather than restricted to trusted hosts.
- Medium Risk — SMB Message Signing Disabled: leaves SMB traffic open to relay/MITM attacks. High Risk (scanner-reported) — PHP-CGI Argument Injection (CVE-2012-1823): detected by Nuclei against the outdated PHP install; not independently exploited but consistent with the confirmed PHP version, flagged as a priority to verify and patch.

Recommended Actions:

- Immediate: Disable Telnet and anonymous FTP; remove/restrict phpinfo.php and phpMyAdmin from public access; isolate this server from any production-adjacent network
- Short term: Upgrade or replace the Apache/PHP stack; restrict MySQL/PostgreSQL to trusted hosts only; enable SMB message signing; disable directory indexing
- Process: Establish a secure baseline/hardening checklist for future server deployments; review NFS/RPC export configuration; schedule periodic re-scans

Limitations: This assessment was an unauthenticated network scan only; no exploitation was performed. Automated scanner output (Nikto, Nuclei) may include false positives and has been cross-checked against Nmap evidence where possible; findings not independently verified are labelled accordingly throughout this report.

8. Deliverables Checklist

- ☑ Nmap output files (ports_only.nmap, ports_only.xml, service_scan — captured via terminal/cat screenshots)
- ☑ Screenshot of the Nmap HTML report (ports_only_report.html)
- ☑ Nikto scan output (terminal screenshot, nikto_scan.txt)
- ☑ Nuclei web scan output (nuclei_web_scan.txt)
- ☑ Nuclei full scan output (nuclei_full_scan.txt)
- ☑ Completed Risk Assessment Table (Section 5)
- ☑ Executive Summary (Section 7)